

Чт, 11 июн. в 12:47

iso-mek-27001-2022.pdf  
PDF

Изучи стандарт ISO/IEC 27001 Информационная безопасность, кибербезопасность и защита персональных данных – Системы менеджмента информационной безопасности – Требования. Что из данных требований можно применить к оценке защиты почтового и web трафика (web proxy, почтовый сервис)

Я изучил предоставленный стандарт ISO/IEC 27001:2022. iso-mek-27001-2022

Для оценки защищенности **почтового сервиса (Exchange, M365, Postfix, SEG и т.д.) и Web Proxy (Zscaler, Squid, Blue Coat, FortiProxy, Forcepoint, SWG и т.д.)** стандарт можно использовать как основу для проведения аудита безопасности. Более того, некоторые меры управления непосредственно относятся к защите web- и email-трафика.

# 1. Общие требования ISMS, применимые к Web Proxy и Email

## 4. Контекст организации

### 4.1 Понимание среды

Для web/email необходимо определить:

- какие сервисы защищаются;
- какие угрозы актуальны:
  - фишинг;
  - malware;
  - ransomware;
  - утечка данных;
  - C2-трафик;
  - обход web proxy;
  - компрометация почтовых ящиков;
  - BEC (Business Email Compromise).

## 4.2 Требования заинтересованных сторон

Для почты и web:

- законодательство;
- GDPR/152-ФЗ;
- требования клиентов;
- требования регуляторов;
- требования SOC.

 iso-mek-27001-2022

## 2. Управление рисками

Это основной раздел.

### 6.1 Оценка рисков

Для почтовой системы:

| Угроза       | Последствие                   |
|--------------|-------------------------------|
| Фишинг       | компрометация учетных записей |
| Malware      | заражение инфраструктуры      |
| Spoofing     | финансовые потери             |
| Data leakage | утечка данных                 |

Для Web Proxy:

| Угроза                  | Последствие     |
|-------------------------|-----------------|
| Доступ к malware сайтам | заражение       |
| Shadow IT               | утечки          |
| Обход proxy             | потеря контроля |
| SSL bypass              | скрытый трафик  |

Стандарт требует:

- идентификации рисков;
- оценки вероятности;

- оценки ущерба;
- определения владельца риска;
- выбора мер защиты.

 iso-mek-27001-2022

---

## 3. Приложение А — наиболее важные меры

Теперь самое интересное.

---

### A.5.7 Threat Intelligence

Очень актуально.

Для email:

- ✓ обновление IOC;
- ✓ RBL;
- ✓ anti-spam feeds;
- ✓ phishing feeds.

Для Web:

- ✓ URL reputation;
- ✓ malware feeds;
- ✓ DNS reputation;
- ✓ IP reputation.

 iso-mek-27001-2022

---

### A.5.12 Классификация информации

Почтовый сервис:

- Confidential;
- Internal;
- Public.

## Web Proxy:

- контроль доступа к чувствительным данным;
- DLP.

 iso-mek-27001-2022

---

## A.5.14 Передача информации

Практически полностью относится к почте.

Проверяется наличие:

- TLS;
- SMTPS;
- STARTTLS;
- S/MIME;
- PGP;
- защищенных каналов передачи файлов;
- правил обмена информацией.

 iso-mek-27001-2022

---

## A.5.15 Управление доступом

Для Email:

- MFA;
- RBAC;
- администраторские роли;
- shared mailbox.

Для Proxy:

- авторизация пользователей;
- групповые политики;
- административный доступ.

 iso-mek-27001-2022

---

## A.5.16–5.18 Identity & Access

Проверяется:

- жизненный цикл учетных записей;

- управление паролями;
- MFA;
- отзыв доступа;
- PAM;
- сервисные аккаунты.

 iso-mek-27001-2022

---

## A.5.19–5.23 Поставщики

Если используются:

- Microsoft 365;
- Proofpoint;
- Mimecast;
- Cisco Umbrella;
- Zscaler;
- Cloudflare Gateway;

необходимо:

- SLA;
- security requirements;
- контроль изменений;
- аудит поставщика.

 iso-mek-27001-2022

---

## A.5.24–5.28 Incident Management

Для почты:

- phishing;
- malware;
- account compromise.

Для Proxy:

- C2;
- TOR;
- botnet;
- DNS tunneling.

Проверяется:

- процедуры;

- расследования;
- сохранение доказательств;
- lessons learned.

 iso-mek-27001-2022

---

## A.5.30 Business Continuity

Для Email:

- DR;
- резервные MX;
- backup mailbox.

Для Proxy:

- HA;
- кластер;
- резервные каналы;
- failover.

 iso-mek-27001-2022

---

## A.5.34 Privacy

Особенно важно.

Проверяется:

- защита персональных данных;
- контроль обработки;
- журналирование;
- минимизация хранения.

 iso-mek-27001-2022

---

## A.5.37 Документированные процедуры

Должны существовать:

Для Email:

- создание mailbox;
- удаление;

- quarantine;
- incident response;
- spam handling.

Для Proxy:

- whitelist;
- blacklist;
- SSL inspection;
- bypass;
- emergency rules.

 iso-mek-27001-2022

---

## Технологические меры (раздел 8)

Это наиболее практичные пункты для технического аудита.

### A.8.5 Безопасная аутентификация

Проверить:

- MFA;
- Conditional Access;
- OAuth;
- Legacy Authentication disable.

 iso-mek-27001-2022

---

### A.8.7 Malware Protection

Email:

- AV;
- sandbox;
- attachment scanning.

Web:

- malware scanning;
- download inspection.

 iso-mek-27001-2022

---

### A.8.8 Vulnerability Management

Проверить:

- обновления Proxy;
- обновления почтового шлюза;
- CVE management;
- hardening.

 iso-mek-27001-2022

---

## A.8.9 Configuration Management

Для аудита очень важно.

Проверяется:

- baseline;
- backup config;
- version control;
- change management.

 iso-mek-27001-2022

---

## A.8.12 Data Leakage Prevention

Email:

- DLP policies;
- блокировка вложений;
- шифрование.

Web:

- upload control;
- cloud storage;
- clipboard;
- file transfer.

 iso-mek-27001-2022

---

## A.8.15 Logging

Для Email:

- SMTP;
- admin actions;



- mailbox audit;
- transport rules.

Для Proxy:

- URL;
- DNS;
- SSL;
- uploads;
- downloads.

Проверяется защита и хранение логов.

 iso-mek-27001-2022

---

## A.8.16 Monitoring

Необходимо наличие:

- SIEM;
- SOC;
- UEBA;
- alerting;
- IOC detection.

 iso-mek-27001-2022

---

## A.8.20 Network Security

Проверяется:

- сегментация;
- firewall;
- DMZ;
- reverse proxy;
- WAF (если применимо).

 iso-mek-27001-2022

---

## A.8.21 Network Services

Для Email:

- SMTP;
- IMAPS;

- POP3S;
- MAPI;
- ActiveSync.

Для Proxy:

- HTTP;
- HTTPS;
- SOCKS;
- PAC;
- Explicit/Transparent mode.

 iso-mek-27001-2022

---

## A.8.23 Web Filtering

Это прямое требование для Web Proxy:

доступ к внешним веб-сайтам должен находиться под управлением для снижения воздействия вредоносного содержимого.

Проверяется:

- URL filtering;
- Category filtering;
- Safe Search;
- HTTPS inspection;
- block pages;
- malware sites;
- phishing sites.

 iso-mek-27001-2022

---

## A.8.24 Cryptography

Для Email:

- TLS;
- S/MIME;
- DKIM.

Для Proxy:

- TLS inspection;
- certificate management;
- key management.

## Практический результат

Если строить аудит защищенности **почтового сервиса и Web Proxy по ISO/IEC 27001:2022**, то наиболее релевантными будут **23 меры контроля**:

**Организационные:** 5.7, 5.12, 5.14–5.24, 5.30, 5.34, 5.37.

**Технологические:** 8.5, 8.7–8.9, 8.12, 8.15, 8.16, 8.20, 8.21, 8.23, 8.24.

Для практики Application Security и Security Architecture из этого стандарта можно сформировать **единый аудит-чеклист примерно из 100–150 проверок** отдельно для:

1. Почтового сервиса (Email Security Gateway/M365/Exchange).
2. Web Proxy/Secure Web Gateway.
3. Общих организационных процессов управления этими сервисами по ISO 27001.

сформируй чек-лист

Ниже приведен **чек-лист аудита защищенности почтового сервиса и Web Proxy на основе ISO/IEC 27001:2022**. Он ориентирован на проведение аудита Application Security, Infrastructure Security и Security Architecture.

Основой являются требования разделов 4-10 стандарта и средства управления Приложения А.

iso-mek-27001-2022

iso-mek-27001-2022

## ЧЕК-ЛИСТ

### 1. Governance и управление

| Проверка                             | Да/Нет | Комментарий |
|--------------------------------------|--------|-------------|
| Определен владелец почтового сервиса |        |             |
| Определен владелец Web Proxy         |        |             |
| Определены роли администраторов      |        |             |

| Проверка                                                                                                 | Да/Нет | Комментарий |
|----------------------------------------------------------------------------------------------------------|--------|-------------|
| Существует политика использования электронной почты                                                      |        |             |
| Существует политика использования Интернет                                                               |        |             |
| Определены допустимые способы передачи информации                                                        |        |             |
| Определены категории пользователей                                                                       |        |             |
| Выполняется периодический пересмотр политик                                                              |        |             |
| ISO:                                                                                                     |        |             |
| <ul style="list-style-type: none"> <li>• 5.1</li> <li>• 5.2</li> <li>• A.5.1</li> <li>• A.5.2</li> </ul> |        |             |

## 2. Управление рисками

| Проверка                                                                 |
|--------------------------------------------------------------------------|
| Выполнен анализ рисков Email                                             |
| Выполнен анализ рисков Web Proxy                                         |
| Определены владельцы рисков                                              |
| Определены меры обработки рисков                                         |
| Оценка рисков проводится регулярно                                       |
| Учитываются новые угрозы                                                 |
| ISO:                                                                     |
| <ul style="list-style-type: none"> <li>• 6.1</li> <li>• A.5.7</li> </ul> |

## 3. Управление доступом

### Email

- ☐ MFA включена
  - ☐ Legacy Authentication отключена
  - ☐ Shared mailbox контролируются
  - ☐ Администраторские роли минимизированы
  - ☐ Используется RBAC
  - ☐ Выполняется регулярный review доступа
  - ☐ Сервисные аккаунты контролируются
- 

### Web Proxy

- ☐ Proxy требует аутентификации
- ☐ Используется SSO
- ☐ Используются группы AD/AAD
- ☐ Администраторские роли разделены
- ☐ Выполняется review привилегий

ISO:

A.5.15

A.5.16

A.5.17

A.5.18

A.8.2

A.8.5

---

## 4. Почтовая безопасность

## SMTP

- ☐ STARTTLS
  - ☐ SMTPS
  - ☐ TLS enforced
  - ☐ Opportunistic TLS контролируется
- 

## Email Authentication

- ☐ SPF
  - ☐ DKIM
  - ☐ DMARC
  - ☐ DMARC reject/quarantine
  - ☐ ARC
  - ☐ BIMI (если используется)
- 

## Anti-spam

- ☐ Reputation
  - ☐ RBL
  - ☐ Greylisting
  - ☐ URL rewriting
  - ☐ Attachment scanning
  - ☐ Sandboxing
  - ☐ Malware detection
  - ☐ Phishing detection
  - ☐ BEC detection
  - ☐ Impersonation protection
-

## Mail Flow

- ☐ Transport Rules
  - ☐ Attachment restrictions
  - ☐ Dangerous extensions blocked
  - ☐ Auto-forward контролируется
  - ☐ External sender tagging
  - ☐ Quarantine работает
- 

## Data Protection

- ☐ DLP
- ☐ Email encryption
- ☐ S/MIME
- ☐ PGP
- ☐ Sensitive labels

ISO:

A.5.14

A.8.7

A.8.12

A.8.24

---

## 5. Web Proxy

### URL Filtering

- ☐ Category filtering
- ☐ Reputation filtering
- ☐ Malware URL

- ☐ Phishing URL
  - ☐ Newly registered domains
  - ☐ Dynamic categorization
- 

## **HTTPS Inspection**

- ☐ SSL Inspection включена
  - ☐ Исключения документированы
  - ☐ Certificate management
  - ☐ TLS 1.2+
- 

## **Download Protection**

- ☐ File scanning
  - ☐ Sandbox
  - ☐ Dangerous MIME blocked
  - ☐ Executable restrictions
- 

## **Upload Control**

- ☐ Cloud upload control
  - ☐ DLP
  - ☐ File type restrictions
  - ☐ Shadow IT detection
- 

## **DNS**

- ☐ DNS filtering
- ☐ DNS tunneling detection
- ☐ DGA detection



ISO:

A.8.23

A.8.20

A.8.21

A.8.12

A.8.24

---

## 6. Threat Intelligence

- ☐ IOC feeds
- ☐ URL reputation
- ☐ IP reputation
- ☐ Domain reputation
- ☐ Malware feeds
- ☐ Phishing feeds
- ☐ Threat feeds обновляются автоматически

ISO:

A.5.7

---

## 7. Защита от вредоносного ПО

### Email

- ☐ AV
- ☐ Sandboxing
- ☐ Attachment detonation
- ☐ Macro detection
- ☐ Archive inspection

## **Proxy**

- ☐ Download scanning
- ☐ Script inspection
- ☐ Executable inspection
- ☐ Archive inspection

ISO:

A.8.7

---

## **8. Управление конфигурациями**

- ☐ Baseline существует
- ☐ Secure Hardening
- ☐ Backup конфигураций
- ☐ Version Control
- ☐ Change Management
- ☐ Emergency Change Process
- ☐ Configuration Review

ISO:

A.8.9

A.8.32

---

## **9. Управление уязвимостями**

- ☐ Проводится vulnerability scanning
- ☐ Проводится patch management
- ☐ Используется CVE monitoring

- ☐ Выполняется hardening review
- ☐ Critical CVE устраняются в SLA

ISO:

A.8.8

---

## 10. Логирование

### Email

- ☐ SMTP logs
  - ☐ Authentication logs
  - ☐ Mailbox audit
  - ☐ Admin actions
  - ☐ Transport rules
  - ☐ Quarantine
- 

### Proxy

- ☐ URL logs
  - ☐ User logs
  - ☐ DNS logs
  - ☐ Upload logs
  - ☐ Download logs
  - ☐ SSL logs
  - ☐ Admin logs
- 

- ☐ Логи защищены
- ☐ Логи передаются в SIEM

- ☐ Время синхронизировано
- ☐ Retention policy определена

ISO:

A.8.15

A.8.16

A.8.17

---

## 11. Мониторинг

- ☐ SIEM интеграция
- ☐ SOC мониторинг
- ☐ Alerting
- ☐ UEBA
- ☐ IOC correlation
- ☐ Anomaly detection
- ☐ Dashboard
- ☐ SLA реагирования

ISO:

A.8.16

---

## 12. DLP

- ☐ Email DLP
- ☐ Web DLP
- ☐ Credit Card
- ☐ Passport
- ☐ Personal Data

- Source Code
- Intellectual Property
- Custom patterns

ISO:

A.5.34

A.8.12

---

## 13. Incident Response

- Процедура обработки фишинга
- Процедура обработки malware
- Процедура BEC
- Процедура утечки данных
- Процедура компрометации аккаунта
- Процедура компрометации Proxy
- Evidence Collection
- Lessons Learned

ISO:

A.5.24

A.5.25

A.5.26

A.5.27

A.5.28

---

## 14. Backup и Recovery

Email

- ☐ Backup mailbox
  - ☐ Backup configuration
  - ☐ Restore testing
- 

## **Proxy**

- ☐ Config backup
  - ☐ Policy backup
  - ☐ Restore testing
- 

- ☐ Recovery Procedure
- ☐ DR Procedure

ISO:

A.5.29

A.5.30

A.8.13

A.8.14

---

## **15. Поставщики**

- ☐ SLA
- ☐ Security Requirements
- ☐ Cloud Risk Assessment
- ☐ Third-party Review
- ☐ Изменения поставщика контролируются
- ☐ Vendor Incident Notification

ISO:

A.5.19

A.5.20

A.5.21

A.5.22

A.5.23

---

## 16. Compliance

- ☐ GDPR/152-ФЗ
- ☐ Privacy
- ☐ Data Retention
- ☐ Email Archive
- ☐ Legal Hold
- ☐ Audit Trail
- ☐ Соответствие внутренним политикам

ISO:

A.5.31

A.5.33

A.5.34

A.5.36

---

## 17. Метрики эффективности (KPI/KRI)

| Метрика       | Значение |
|---------------|----------|
| MFA coverage  | ____%    |
| SPF coverage  | ____%    |
| DKIM coverage | ____%    |

| Метрика                  | Значение |
|--------------------------|----------|
| DMARC reject             | Да/Нет   |
| Blocked phishing         | _____    |
| Blocked malware          | _____    |
| Web malicious blocks     | _____    |
| DLP incidents            | _____    |
| Mean Time to Detect      | _____    |
| Mean Time to Respond     | _____    |
| Critical vulnerabilities | _____    |
| Patch SLA compliance     | _____ %  |
| Log coverage             | _____ %  |
| Backup success           | _____ %  |
| Restore success          | _____ %  |

## Критерии зрелости

Этот чек-лист можно использовать для оценки зрелости сервиса:

| Уровень | Описание                                                                   |
|---------|----------------------------------------------------------------------------|
| L1      | Базовые меры безопасности, реактивная защита                               |
| L2      | Формализованные процессы, базовый мониторинг                               |
| L3      | Централизованное управление, SIEM, DLP, Threat Intelligence                |
| L4      | Автоматизация, UEBA, SOAR, непрерывный контроль                            |
| L5      | Adaptive Security, риск-ориентированное управление, постоянная оптимизация |



Такой формат хорошо подходит как для внутреннего аудита по ISO 27001, так и для оценки зрелости решений класса **Secure Email Gateway (SEG)** и **Secure Web Gateway (SWG)**, а также может использоваться в качестве опросного листа при проведении аудита безопасности инфраструктуры.

Чт, 11 июн. в 14:46

<https://www.sberbank.ru/ru/person/kibrary/experts/metodika-ocenki-urovnya-zrelosti-kiberbezopasnosti-fokusnykh-kompanij-gruppy-pao-sberbank>

изучит эту методику, что можно применить ?

Да. Я ознакомился с методикой Сбера и могу сказать, что **она может существенно улучшить разработанный нами чек-лист ISO 27001**. Но нужно понимать разницу в подходах.

- **ISO 27001** отвечает на вопрос: "Есть ли необходимые процессы и меры контроля?"
- **Методика Сбера** отвечает на вопрос: "Насколько зрело эти процессы реализованы и насколько они эффективны?"

 Сбербанк +2

## Что интересного в методике Сбера

Основная идея методики состоит не в наличии/отсутствии контроля, а в оценке зрелости по уровням.

Типичная логика выглядит примерно так:

| Уровень | Характеристика                                  |
|---------|-------------------------------------------------|
| У1      | Базовые меры реализованы                        |
| У2      | Процессы формализованы                          |
| У3      | Процессы управляются и измеряются               |
| У4      | Процессы автоматизированы                       |
| У5      | Процессы адаптивны и постоянно совершенствуются |

Это гораздо ближе к CMMI и NIST CSF maturity, чем к классическому ISO.

---

## Что можно применить для Email и Web Proxy

Я бы позаимствовал несколько ключевых принципов.

---

### 1. Оценивать не факт наличия контроля, а его зрелость

Например.

ISO:

Есть ли DLP?

Да/Нет.

Сбер:

#### У1

Есть базовые DLP правила.

#### У2

Есть классификация данных.

#### У3

Есть централизованное управление DLP.

#### У4

Есть автоматическая настройка политик.

#### У5

Есть UEBA и adaptive DLP.

---

Это намного полезнее для аудита.

---

### 2. Разбить аудит на направления

У Сбера вся методика состоит из направлений.

Например:

1. Управление
2. Активы
3. Данные
4. Идентификация
5. Сети
6. Инциденты
7. Мониторинг
8. Уязвимости
9. Поставщики
10. Тестирование



 Сервис управл... +1

Для Email/Web Proху можно использовать:

1. Governance
2. Identity
3. Email Security
4. Web Security
5. Data Protection
6. Threat Intelligence
7. Logging
8. Monitoring
9. Incident Response
10. Resilience
11. Third Party
12. Compliance



---

### 3. Использовать требования по уровням зрелости

Это очень хороший подход.

Например.

## Email Authentication

### Y1

SPF.

### Y2

SPF + DKIM.

### Y3

DMARC monitoring.

### Y4

DMARC reject.

### Y5

ARC + BIMI + автоматический мониторинг.

---

## Web Filtering

### Y1

Blacklist.

### Y2

Category filtering.

### Y3

SSL Inspection.

### Y4

Sandbox.

### Y5

AI/ML Risk Scoring.

---

## 4. Проверять автоматизацию

ISO говорит:

"Логи должны собираться."

Сбер говорит:

"Логи должны автоматически анализироваться."

Например.

---

## **У1**

Есть логи.

## **У2**

Есть SIEM.

## **У3**

Есть use-cases.

## **У4**

Есть SOAR.

## **У5**

Есть UEBA и автоматическое реагирование.

---

Для Email:

- Mailbox audit;
- Transport logs;
- Admin logs.

Для Proxy:

- URL;
  - DNS;
  - SSL;
  - Downloads.
- 

## **5. Проверять защищенность данных**

Это один из самых сильных разделов методики.

Например.

## **У1**

Определены защищаемые данные.

## **У2**

Есть классификация.

## **У3**

Есть маркировка.

## **У4**

Есть DLP.

## **У5**

Есть автоматическая классификация.

 Сервис управл... +1

Для Email это особенно полезно.

---

## **6. Проверять PenTest и Assessment**

Очень хорошая идея.

Например.

## **У1**

Проводится ежегодный pentest.

## **У2**

Есть remediation plan.

## **У3**

Проверяется выполнение remediation.

## **У4**

Есть continuous assessment.

## **У5**

Есть BAS и continuous validation.

## 7. Ввести количественные показатели

Это одно из главных достоинств методики.

Не просто:

MFA есть.



А:

MFA coverage = 97%.



Не:

DLP работает.



А:

95% исходящей почты проверяется DLP.



Для Email:

### КРІ

MFA Coverage

SPF Coverage

DKIM Coverage

DMARC Reject

BEC Detection Rate

False Positive Rate

Email Encryption Coverage

Для Proxy:

## KPI

HTTPS Inspection Coverage

URL Filtering Coverage

Malware Block Rate

Shadow IT Detection

TLS Inspection Coverage

DLP Coverage

## 8. Проверять процессы эксплуатации

Это сильная сторона методики Сбера.

Не просто:

Есть Proxy.



А:

Кто обновляет?

Как часто?

Есть SLA?

Есть owner?

Есть backup?

Есть rollback?

Есть change management?



## Самое полезное для нашего чек-листа

Я бы объединил оба подхода следующим образом:

ISO 27001

Методика Сбера

Что должно быть

Насколько хорошо реализовано

Compliance

Maturity



| ISO 27001 | Методика Сбера        |
|-----------|-----------------------|
| Контроли  | Уровни зрелости       |
| Да/Нет    | У1–У5                 |
| Политики  | KPI                   |
| Аудит     | Continuous Assessment |

## Для аудита почтового сервиса и Web Proху наиболее практичной будет гибридная модель:

**Уровень 1:** соответствие требованиям ISO 27001 (контроль существует).

**Уровень 2:** оценка зрелости по методике Сбера (У1–У5).

**Уровень 3:** количественные KPI/KRI (охват MFA, DMARC, DLP, SIEM, TLS Inspection и т.д.).

Такой подход даст не только ответ **"соответствует ли сервис требованиям"**, но и позволит объективно оценить его зрелость и построить дорожную карту развития кибербезопасности для Email Security и Secure Web Gateway.

распиши более подробно, почему и как применимы меры А 5.7 5.14 5.15 5.16 5.17 5.18 5.19 5.20 5.21 5.22 5.23 5.24 5.30 5.37

Обработка заняла 19s >

Ниже — подробное обоснование применимости мер **ISO/IEC 27001:2022 Annex A** к оценке защищенности **почтового сервиса** и **Web Proxy / Secure Web Gateway**. Я рассматриваю эти меры не как формальный список, а как основу для аудита: **что проверять, зачем это важно и какие доказательства собирать**. Основа — Приложение А стандарта ISO/IEC 27001:2022.  iso-mek-27001-2022

## A.5.7 Изучение угроз / Threat Intelligence

### Почему применимо

Почтовый сервис и Web Proху являются одними из основных каналов доставки угроз:

- фишинг;

- вредоносные вложения;
- вредоносные URL;
- credential harvesting;
- C2-коммуникации;
- загрузка malware через web;
- переходы на newly registered domains;
- обход корпоративных политик через anonymizer/VPN/TOR.

Без актуальной информации об угрозах почтовый шлюз и проху работают только на статических правилах. Это снижает эффективность защиты.

## Как применить к почте

Проверить, используются ли:

- anti-phishing feeds;
- reputation feeds для доменов, IP и URL;
- IOC по фишинговым кампаниям;
- sandbox intelligence;
- threat intelligence от вендора SEG;
- блокировка доменов-имитаторов;
- detection BEC / impersonation;
- обновление сигнатур malware;
- интеграция с SOC/SIEM/TIP.

## Как применить к Web Proxy

Проверить наличие:

- URL reputation;
- DNS reputation;
- IP reputation;
- категорий вредоносных сайтов;
- блокировки newly registered domains;
- блокировки phishing/malware/C2;
- threat feeds от вендора SWG;
- интеграции с TI-платформой;
- автоматической загрузки IOC в proxy/DNS/firewall.

## Что запросить как доказательства

- перечень используемых threat intelligence sources;
- настройки подписок/feeds;
- частоту обновления IOC;
- примеры заблокированных угроз;

- отчеты по фишинговым кампаниям;
- интеграции с SIEM/SOAR/TIP;
- процедуры обработки новых IOC.

## Примеры вопросов аудитора

| Вопрос                                                            | Ожидаемый результат                                    |
|-------------------------------------------------------------------|--------------------------------------------------------|
| Какие источники threat intelligence используются для email и web? | Есть утвержденный перечень источников                  |
| Как часто обновляются IOC?                                        | Автоматически или по SLA                               |
| Как IOC попадают в SEG/SWG?                                       | Через API, SIEM, TIP или вендорские feeds              |
| Есть ли ретроспективный поиск по IOC?                             | Возможен поиск по логам почты/проху                    |
| Используются ли IOC после инцидентов?                             | Lessons learned превращаются в правила detection/block |

## Признак хорошей зрелости

Не просто «есть threat feeds», а есть процесс:

получение угроз → оценка релевантности → внедрение правила → мониторинг срабатываний 

## A.5.14 Передача информации / Information Transfer

### Почему применимо

Email и web-трафик — это каналы передачи информации. Через них передаются:

- персональные данные;
- коммерческая тайна;
- документы;
- исходный код;
- учетные данные;
- финансовая информация;
- вложения;
- файлы в облачные сервисы.

Поэтому мера A.5.14 напрямую применима к оценке того, **как организация контролирует передачу информации наружу и внутри компании.**

## Как применить к почте

Проверить:

- используется ли TLS для SMTP;
- есть ли политика обязательного TLS для критичных контрагентов;
- применяется ли S/MIME или PGP для чувствительной переписки;
- контролируются ли вложения;
- запрещены ли опасные типы файлов;
- используются ли DLP-правила;
- есть ли классификация писем;
- применяется ли шифрование исходящих писем;
- контролируется ли auto-forward на внешние адреса;
- запрещена ли пересылка чувствительных данных на личную почту;
- логируются ли действия с пересылкой.

## Как применить к Web Proxy

Проверить:

- контролируется ли upload файлов во внешние сервисы;
- есть ли политики для cloud storage;
- разрешены ли личные облака: Google Drive, Dropbox, Яндекс Диск и т.д.;
- применяется ли DLP на web upload;
- есть ли SSL inspection для анализа HTTPS-трафика;
- есть ли исключения из SSL inspection и кто их утверждает;
- контролируются ли web-mail сервисы;
- блокируются ли anonymous file sharing;
- контролируются ли paste-сервисы;
- проверяется ли передача данных в SaaS.

## Что запросить как доказательства

- политика передачи информации;
- правила mail flow / transport rules;
- правила DLP;
- список доменов с enforced TLS;
- список исключений из SSL inspection;
- отчеты DLP;
- журналы отправки чувствительных данных;
- регламент обмена с внешними сторонами.

## Примеры вопросов аудитора

| Вопрос                                                   | Ожидаемый результат             |
|----------------------------------------------------------|---------------------------------|
| Какие типы информации можно передавать по email?         | Определено политикой            |
| Как защищается чувствительная переписка?                 | TLS, encryption, DLP, labels    |
| Можно ли отправить персональные данные на внешний домен? | Контролируется DLP и политиками |
| Можно ли загрузить корпоративный файл в личное облако?   | Запрещено или контролируется    |
| Кто утверждает исключения?                               | Есть процесс согласования       |

## Признак хорошей зрелости

Передача информации контролируется не только технически, но и процессно:

классификация данных → правила передачи → технический контроль → журналирование → 

## A.5.15 Управление доступом / Access Control

### Почему применимо

Почтовый сервис и Web Proxu обрабатывают большое количество чувствительной информации. Ошибки в доступе приводят к:

- чтению чужой почты;
- изменению mail flow rules;
- отключению защитных политик;
- обходу проху;
- несанкционированному доступу к логам;
- изменению white list / bypass;
- компрометации администраторских учетных записей.

### Как применить к почте

Проверить:

- кто имеет доступ к администрированию почтового сервиса;
- разделены ли роли Global Admin, Exchange Admin, Security Admin;
- используется ли RBAC;
- ограничен ли доступ к mailbox audit logs;

- контролируется ли доступ к shared mailbox;
- есть ли MFA для администраторов;
- запрещен ли доступ по legacy protocols;
- ограничены ли application permissions;
- контролируются ли service accounts.

## Как применить к Web Proxy

Проверить:

- требуется ли аутентификация пользователей;
- используется ли интеграция с AD/AAD/LDAP;
- есть ли разные политики по группам;
- ограничен ли доступ к административной консоли;
- используется ли MFA для администраторов;
- разделены ли роли: viewer, policy admin, full admin;
- кто может создавать bypass;
- кто может добавлять сайты в whitelist;
- кто может отключать SSL inspection.

## Что запросить как доказательства

- матрицу ролей;
- список администраторов;
- RBAC-модель;
- правила проху-политик;
- список service accounts;
- отчеты access review;
- логи административных действий;
- evidence по MFA.

## Примеры вопросов аудитора

| Вопрос                                          | Ожидаемый результат                 |
|-------------------------------------------------|-------------------------------------|
| Кто может менять политики почты/проху?          | Только уполномоченные роли          |
| Есть ли регулярный пересмотр прав?              | Да, по утвержденному графику        |
| Используется ли принцип минимальных привилегий? | Да, подтверждается матрицей доступа |
| Логируются ли действия администраторов?         | Да, с передачей в SIEM              |
| Есть ли break-glass accounts?                   | Да, контролируются отдельно         |

## A.5.16 Управление идентификацией / Identity Management

### Почему применимо

Для email и проху критично понимать, **кто именно выполняет действие**:

- кто отправил письмо;
- кто открыл вредоносную ссылку;
- кто загрузил файл во внешний сервис;
- кто изменил политику проху;
- кто создал mail forwarding rule;
- кто добавил домен в allow list.

Если идентификация пользователей и сервисных учетных записей не управляется, расследование инцидентов становится ненадежным.

### Как применить к почте

Проверить:

- учетные записи пользователей создаются через официальный IAM-процесс;
- отключаются при увольнении;
- блокируются неактивные mailbox;
- контролируются shared mailbox;
- есть владелец у каждого shared mailbox;
- сервисные аккаунты имеют владельцев;
- application identities зарегистрированы;
- запрещены анонимные/общие админские учетные записи.

### Как применить к Web Proxy

Проверить:

- проху идентифицирует пользователя, а не только IP;
- есть интеграция с IdP;
- корректно работает SSO;
- гостевой трафик отделен от корпоративного;
- сервисные аккаунты проху имеют владельцев;
- исключения по IP не заменяют полноценную идентификацию;
- логи содержат пользователя, устройство, IP, группу, действие.

### Что запросить как доказательства

- IAM-процесс;
- lifecycle user accounts;

- список service accounts;
- список shared mailbox;
- список proxy admin accounts;
- mapping user → group → policy;
- логи с идентификатором пользователя;
- отчеты по неактивным учетным записям.

## Признак хорошей зрелости

В логах email и проху можно точно восстановить:

кто → когда → откуда → что сделал → по какой политике было разрешено или запрещено



## A.5.17 Информация для аутентификации / Authentication Information

### Почему применимо

Эта мера касается управления секретами аутентификации:

- паролями;
- токенами;
- API keys;
- сертификатами;
- OAuth secrets;
- service account credentials;
- ключами DKIM;
- ключами TLS;
- учетными данными proxy integration.

Компрометация таких данных может привести к полному обходу защиты.

### Как применить к почте

Проверить:

- используются ли MFA и passwordless;
- отключена ли legacy authentication;
- защищены ли OAuth application secrets;
- контролируются ли SMTP AUTH exceptions;
- есть ли rotation DKIM keys;
- защищены ли TLS private keys;
- контролируются ли service account passwords;



- используются ли Conditional Access policies.

## Как применить к Web Proxy

Проверить:

- защищены ли admin passwords;
- MFA для административной консоли;
- ротация API tokens;
- защита сертификатов для SSL inspection;
- хранение private key для root/intermediate CA;
- защищены ли LDAP bind credentials;
- есть ли vault для секретов;
- есть ли запрет хранения паролей в скриптах.

## Что запросить как доказательства

- password policy;
- MFA policy;
- Conditional Access policy;
- список исключений из MFA;
- список legacy auth exceptions;
- vault evidence;
- регламент ротации секретов;
- список сертификатов и сроков действия;
- порядок доступа к private keys.

## Примеры вопросов аудитора

| Вопрос                                         | Ожидаемый результат                |
|------------------------------------------------|------------------------------------|
| Где хранятся секреты сервисных аккаунтов?      | В vault или защищенном хранилище   |
| Как часто меняются API tokens?                 | По регламенту или при инциденте    |
| Кто имеет доступ к SSL inspection private key? | Ограниченный круг лиц              |
| Отключена ли legacy authentication?            | Да, исключения обоснованы          |
| Есть ли MFA для администраторов?               | Да, без исключений или с контролем |

## A.5.18 Права доступа / Access Rights

## Почему применимо

Если A.5.15 отвечает за саму модель доступа, то A.5.18 — за жизненный цикл прав:

выдача → изменение → пересмотр → отзыв



Для почты и проху это особенно важно, потому что администраторские права позволяют изменить защитные механизмы.

## Как применить к почте

Проверить:

- заявки на выдачу прав;
- согласование владельцем сервиса;
- регулярный review Exchange/M365 admin roles;
- review mailbox permissions;
- review Send As / Send on Behalf;
- review shared mailbox owners;
- отзыв прав при увольнении;
- отзыв временных доступов;
- контроль break-glass accounts;
- контроль delegated admin rights.

## Как применить к Web Proxy

Проверить:

- кто может создавать политики;
- кто может менять категории;
- кто может делать bypass;
- кто может отключать SSL inspection;
- кто может просматривать логи пользователей;
- кто может экспортировать логи;
- кто может управлять интеграциями;
- есть ли регулярный review прав.

## Что запросить как доказательства

- заявки на доступ;
- approvals;
- access review reports;
- список privileged users;
- список временных доступов;
- логи изменения ролей;
- Joiner/Mover/Leaver process;

- отчеты по уволенным сотрудникам.

## Хороший критерий проверки

Для каждого администратора должно быть понятно:

зачем выдан доступ → кем согласован → на какой срок → когда пересматривался → какие 

## А.5.19 Информационная безопасность в отношениях с поставщиками

### Почему применимо

Email и Web Proxy часто зависят от поставщиков:

- Microsoft 365;
- Google Workspace;
- Proofpoint;
- Mimecast;
- Cisco;
- Zscaler;
- Forcepoint;
- Broadcom/Symantec;
- Fortinet;
- Cloudflare;
- антивирусные движки;
- threat intelligence feeds;
- MDR/SOC-провайдеры;
- cloud/SaaS-платформы.

Поставщик может иметь доступ к трафику, логам, конфигурациям, персональным данным и инцидентам.

### Как применить к почте

Проверить:

- кто поставщик почтовой платформы;
- кто поставщик SEG;
- где обрабатываются письма;
- где хранятся журналы;
- кто имеет доступ к quarantine;
- есть ли доступ поддержки поставщика;

- есть ли требования к защите данных;
- есть ли уведомление об инцидентах.

## Как применить к Web Proxy

Проверить:

- используется ли облачный SWG;
- через какие точки обработки идет трафик;
- где хранятся web-логи;
- кто имеет доступ к логам пользователей;
- какие данные передаются поставщику;
- есть ли DPA/соглашение по ПДн;
- есть ли требования к шифрованию;
- есть ли порядок отключения сервиса.

## Что запросить как доказательства

- реестр поставщиков;
- risk assessment поставщика;
- договоры;
- SLA;
- DPA;
- security addendum;
- SOC 2 / ISO 27001 certificate;
- отчет о vendor assessment;
- матрицу обрабатываемых данных.

---

## А.5.20 Информационная безопасность в соглашениях с поставщиками

### Почему применимо

А.5.19 говорит: «управляйте рисками поставщиков».

А.5.20 говорит: «закрепите требования безопасности в договорах».

Для email/проху это критично, потому что поставщик может быть частью цепочки защиты.

### Что должно быть в договоре для Email/SWG

Проверить наличие требований:

- SLA доступности;

- SLA реагирования на инциденты;
- сроки уведомления об инцидентах;
- требования к шифрованию данных;
- требования к хранению логов;
- требования к удалению данных;
- требования к географии обработки;
- требования к персональным данным;
- право на аудит;
- управление изменениями;
- требования к subcontractors;
- порядок возврата/удаления данных при расторжении;
- ответственность за нарушение.

## Примеры применимости

| Область                 | Что закрепить                                              |
|-------------------------|------------------------------------------------------------|
| Email Security Gateway  | сканирование вложений, quarantine, SLA обновления сигнатур |
| M365 / Google Workspace | доступность, хранение данных, аудит, журналы               |
| Web Proxy / SWG         | обработка web-логов, SSL inspection, DLP, точки обработки  |
| SOC/MDR                 | SLA реагирования, правила эскалации, доступ к логам        |
| TI feeds                | качество данных, SLA обновления, формат IOC                |

## Что запросить как доказательства

- договор;
- SLA;
- security requirements;
- DPA;
- перечень subcontractors;
- матрицу ответственности RACI;
- порядок уведомления об инцидентах.

## A.5.21 Управление ИБ в цепочке поставки ИКТ

## Почему применимо

Email и Web Proxy — это не один продукт, а цепочка компонентов:

IdP → DNS → MX → SEG → Mail Platform → DLP → SIEM → SOC



и

Endpoint → PAC/WPAD → Proxy/SWG → DNS → TLS inspection → DLP → SIEM



Компрометация любого звена может снизить защищенность всего канала.

## Как применить к почте

Проверить цепочку:

- DNS hosting;
- registrar;
- MX records;
- SPF/DKIM/DMARC;
- SEG;
- M365/Exchange/Google;
- DLP;
- archive;
- backup;
- SIEM;
- SOC;
- внешние антиспам/антивирусные движки.

## Как применить к Web Proxy

Проверить цепочку:

- endpoint agent;
- PAC file hosting;
- proxy gateway;
- cloud SWG;
- DNS filtering;
- TLS certificate chain;
- DLP engine;
- identity provider;
- logging pipeline;
- SIEM/SOC;
- CASB integration.

## Типовые риски

| Риск                             | Пример                                             |
|----------------------------------|----------------------------------------------------|
| Зависимость от одного поставщика | отказ облачного проху блокирует доступ в Интернет  |
| Subprocessor risk                | логи пользователей обрабатываются третьей стороной |
| Supply chain compromise          | вредоносное обновление агента проху                |
| Weak DNS control                 | изменение MX или SPF записей                       |
| Certificate risk                 | компрометация CA для SSL inspection                |

## Что запросить как доказательства

- архитектурную схему;
- реестр ИКТ-поставщиков;
- dependency map;
- RACI между поставщиками;
- данные о subcontractors;
- результаты supplier risk assessment;
- планы выхода / exit plan;
- DR-планы по ключевым поставщикам.

## A.5.22 Мониторинг, анализ и управление изменениями услуг поставщиков

### Почему применимо

Даже если поставщик безопасен на момент закупки, его сервис меняется:

- меняются дата-центры;
- меняются subprocessors;
- меняются функции;
- меняются политики хранения логов;
- меняются API;
- меняются правила лицензирования;
- меняется поведение security controls;
- появляются новые CVE;
- отключаются старые протоколы.

Для email и проху такие изменения могут напрямую повлиять на защиту.

## Как применить к почте

Проверить:

- отслеживаются ли изменения M365/Google/SEG;
- анализируются ли изменения в mail flow;
- контролируются ли изменения quarantine policy;
- проверяются ли изменения anti-phishing policy;
- есть ли процесс тестирования новых функций;
- фиксируются ли изменения в transport rules;
- анализируются ли инциденты поставщика.

## Как применить к Web Proxy

Проверить:

- отслеживаются ли изменения SWG-поставщика;
- контролируются ли обновления агента;
- тестируются ли изменения SSL inspection;
- проверяются ли изменения URL categories;
- анализируются ли outages;
- контролируются ли изменения DLP engine;
- согласуются ли новые точки обработки трафика.

## Что запросить как доказательства

- процесс vendor change management;
- уведомления от поставщиков;
- журнал анализа изменений;
- результаты тестирования изменений;
- отчеты SLA;
- отчеты о доступности;
- отчеты об инцидентах поставщика;
- планы корректирующих действий.

## Признак хорошей зрелости

Изменения поставщика не просто читаются в рассылке, а проходят процесс:

уведомление → оценка влияния → тестирование → согласование → внедрение → контроль 



## **A.5.23 Информационная безопасность при использовании облачных сервисов**

### **Почему применимо**

Почта и Web Proxy очень часто являются облачными сервисами:

- Microsoft 365;
- Google Workspace;
- Proofpoint Cloud;
- Mimecast Cloud;
- Zscaler;
- Cloudflare Gateway;
- Cisco Umbrella;
- Netskope;
- Forcepoint Cloud.

Также через проху контролируется доступ пользователей к другим облачным сервисам.

### **Как применить к почте**

Проверить:

- проведена ли оценка облачного почтового сервиса;
- определена ли модель ответственности;
- настроены ли security baseline;
- включен ли audit logging;
- настроены ли retention policies;
- настроен ли Conditional Access;
- контролируется ли external sharing;
- есть ли backup/retention;
- есть ли eDiscovery/legal hold при необходимости.

### **Как применить к Web Proxy**

Проверить:

- утвержден ли облачный SWG;
- определены ли регионы обработки трафика;
- включено ли логирование;
- настроен ли доступ администраторов;
- есть ли SSO/MFA;
- контролируются ли CASB-функции;
- определены ли исключения из инспекции;
- есть ли план отключения/миграции;

- есть ли контроль Shadow IT.

## Что запросить как доказательства

- cloud risk assessment;
- cloud service approval;
- shared responsibility model;
- security baseline;
- настройки tenant security;
- список администраторов;
- отчеты cloud audit logs;
- DPA;
- exit plan.

## Важный критерий

Для облачных email/proxy-сервисов нужно проверять не только «куплен ли сервис», а:

кто отвечает за что → какие данные обрабатываются → где хранятся → кто имеет доступ



## A.5.24 Планирование и подготовка к управлению инцидентами ИБ

### Почему применимо

Почта и web — основные источники security incidents:

- фишинговые письма;
- malware вложения;
- компрометация mailbox;
- BEC;
- массовая рассылка от имени компании;
- переход пользователя на phishing URL;
- скачивание malware;
- C2-трафик;
- утечка данных через web upload;
- обход proxy.

Без заранее подготовленных процедур организация реагирует хаотично.

### Как применить к почте

Должны быть playbooks:

- phishing email investigation;
- mailbox compromise;
- BEC;
- malicious attachment;
- malicious URL;
- spam outbreak;
- suspicious mail forwarding rule;
- mass quarantine/retraction;
- compromised OAuth application;
- credential phishing response.

## Как применить к Web Proxy

Должны быть playbooks:

- user visited malicious site;
- malware download;
- C2 detection;
- DNS tunneling;
- TOR/anonymizer usage;
- data upload to unsanctioned cloud;
- proxy bypass;
- SSL inspection exception abuse;
- credential leak via web form.

## Что запросить как доказательства

- incident response plan;
- email incident playbooks;
- web incident playbooks;
- RACI;
- escalation matrix;
- контакты SOC/IT/Legal/PR/DPO;
- шаблоны уведомлений;
- результаты tabletop exercises;
- отчеты по учениям.

## Хороший критерий проверки

Для каждого типового инцидента должно быть заранее понятно:

кто обнаруживает → кто подтверждает → кто изолирует → кто расследует → кто уведомляет 

## **А.5.30 Готовность ИКТ к обеспечению непрерывности бизнеса**

### **Почему применимо**

Email и web-доступ являются критичными бизнес-сервисами. Их отказ влияет на:

- коммуникации;
- продажи;
- клиентскую поддержку;
- обмен документами;
- доступ к SaaS;
- работу удаленных сотрудников;
- реагирование на инциденты.

Поэтому нужно оценивать не только защиту, но и устойчивость.

### **Как применить к почте**

Проверить:

- резервирование MX;
- отказоустойчивость mail gateway;
- backup mail flow;
- доступность M365/Exchange/Google;
- backup конфигураций;
- backup критичных mailbox;
- recovery procedures;
- тестирование восстановления;
- альтернативные каналы коммуникации;
- RTO/RPO для почты.

### **Как применить к Web Proxy**

Проверить:

- отказоустойчивость проху;
- несколько точек выхода;
- резервные PAC-файлы;
- fallback при отказе SWG;
- HA для on-prem проху;
- резервирование каналов;
- bypass procedures на случай аварии;
- тестирование DR;
- RTO/RPO для проху-сервиса;
- влияние отказа проху на доступ к бизнес-приложениям.

## Что запросить как доказательства

- BIA;
- RTO/RPO;
- DR plan;
- результаты DR-тестов;
- HA-схему;
- backup policy;
- отчеты restore testing;
- процедуры аварийного доступа;
- отчеты об отказах.

## Важный момент

Нужно проверять не только «есть ли резервирование», а были ли сценарии реально протестированы:

отказ почтового шлюза → переключение → доставка писем → восстановление → анализ рез 

и

отказ proxy/SWG → fallback → доступ к критичным SaaS → сохранение контроля безопас 

---

## А.5.37 Документированные операционные процедуры

### Почему применимо

Email и Web Proxy — это высокоизменяемые сервисы. Если процедуры не документированы, возникают риски:

- разные администраторы настраивают по-разному;
- whitelist добавляется без согласования;
- bypass остается навсегда;
- правила DLP меняются без контроля;
- инциденты обрабатываются нестабильно;
- новые сотрудники не понимают процесс;
- невозможно доказать соответствие требованиям аудита.

### Как применить к почте

Должны быть процедуры:

- создание mailbox;

- удаление mailbox;
- управление shared mailbox;
- управление distribution lists;
- настройка transport rules;
- обработка quarantine;
- добавление отправителя в allow/block list;
- настройка SPF/DKIM/DMARC;
- расследование phishing;
- отзыв вредоносных писем;
- отключение auto-forward;
- работа с compromised mailbox;
- backup/restore;
- изменение mail flow.

## **Как применить к Web Proxy**

Должны быть процедуры:

- добавление URL в whitelist;
- добавление URL в blacklist;
- создание policy exception;
- bypass SSL inspection;
- управление категориями URL;
- настройка PAC;
- подключение нового сегмента сети;
- подключение новой группы пользователей;
- анализ web incident;
- экспорт логов;
- изменение DLP policy;
- emergency change;
- rollback изменений.

## **Что запросить как доказательства**

- операционные инструкции;
- runbooks;
- change procedures;
- approval workflow;
- emergency change procedure;
- rollback plan;
- журнал изменений;
- инструкции для L1/L2/L3 поддержки;
- база знаний;

- evidence регулярного пересмотра процедур.

## Хороший критерий проверки

Для каждой регулярной операции должен быть документированный ответ:

кто выполняет → на основании какой заявки → кто согласует → как выполняется → где J 

## Сводная таблица применимости

| Мера ISO      | Почему применима к Email                                     | Почему применима к Web Proxy                     | Что проверять в первую очередь       |
|---------------|--------------------------------------------------------------|--------------------------------------------------|--------------------------------------|
| <b>A.5.7</b>  | Фишинг, malware, BEC, вредоносные URL                        | Malware sites, C2, phishing, TOR, DNS threats    | Threat feeds, IOC, интеграции с SIEM |
| <b>A.5.14</b> | Передача данных через письма и вложения                      | Upload/download данных через web                 | TLS, DLP, encryption, upload control |
| <b>A.5.15</b> | Доступ к mailbox, mail flow, admin console                   | Доступ к proxy policies, logs, bypass            | RBAC, MFA, least privilege           |
| <b>A.5.16</b> | Идентификация отправителя, администратора, владельца mailbox | Идентификация пользователя в web-логах           | IAM lifecycle, SSO, service accounts |
| <b>A.5.17</b> | Пароли, OAuth secrets, DKIM, TLS keys                        | Admin passwords, API tokens, SSL inspection keys | Vault, MFA, rotation, legacy auth    |
| <b>A.5.18</b> | Выдача/отзыв прав к mailbox и админке                        | Выдача/отзыв прав к proxy/SWG                    | Access review, approvals, JML        |
| <b>A.5.19</b> | Зависимость от M365, SEG, anti-spam vendors                  | Зависимость от SWG, DNS, CASB vendors            | Vendor risk assessment               |
| <b>A.5.20</b> | Требования к защите почты в договорах                        | Требования к защите web-трафика в договорах      | SLA, DPA, incident notification      |

| Мера ISO | Почему применима к Email                     | Почему применима к Web Proxy               | Что проверять в первую очередь |
|----------|----------------------------------------------|--------------------------------------------|--------------------------------|
| A.5.21   | Цепочка DNS–MX–SEG–Mail–SIEM                 | Цепочка Endpoint–PAC–SWG–DLP–SIEM          | Supply chain map               |
| A.5.22   | Изменения у M365/SEG влияют на mail security | Изменения SWG влияют на web control        | Vendor change monitoring       |
| A.5.23   | Почта часто облачная                         | Proxy/SWG часто облачный                   | Cloud risk assessment          |
| A.5.24   | Почта — основной источник инцидентов         | Web — основной канал malware/C2/data leak  | Playbooks и readiness          |
| A.5.30   | Почта критична для бизнеса                   | Прoxy критичен для доступа к SaaS/Internet | HA, DR, RTO/RPO                |
| A.5.37   | Нужны runbooks по mail operations            | Нужны runbooks по proxy operations         | Процедуры, change, rollback    |

## Как это использовать в чек-листе

Для каждой меры лучше использовать не формат **Да/Нет**, а зрелостную шкалу:

| Уровень | Описание                                                           |
|---------|--------------------------------------------------------------------|
| 0       | Мера отсутствует                                                   |
| 1       | Есть отдельные технические настройки                               |
| 2       | Есть формализованная процедура                                     |
| 3       | Процедура регулярно выполняется и контролируется                   |
| 4       | Есть метрики, автоматизация, интеграция с SIEM/SOAR                |
| 5       | Мера адаптивна: улучшается по результатам инцидентов, TI и аудитов |

Например для **A.5.24 Incident Management**:



| Уровень | Пример зрелости                                               |
|---------|---------------------------------------------------------------|
| 1       | SOC вручную разбирает фишинг                                  |
| 2       | Есть инструкция по phishing response                          |
| 3       | Есть playbooks для phishing, BEC, malware, mailbox compromise |
| 4       | Есть автоматическое извлечение писем, SOAR, IOC enrichment    |
| 5       | Инциденты автоматически улучшают правила SEG/SWG/DLP и TI     |

Такой подход позволит оценить не только наличие мер ISO 27001, но и реальную зрелость защиты почтового и web-трафика.